

Quais fabricantes concentram as vulnerabilidades já exploradas em ataques reais?

Um data lake na AWS, 100% em Terraform, que responde essa pergunta com dados públicos da CISA — e mede quanto custa cada resposta.

Grupo g07 · CESAR School · 2026.2

Bruno Ribeiro · Emanuel Eduardo · Igor Alves · Leonardo Amaral · Victor Guilherme · Vinícius Petribu

Por que o catálogo KEV: o filtro do ataque real

- **KEV** (*Known Exploited Vulnerabilities*) é o catálogo oficial da **CISA**, a agência de cibersegurança dos EUA: só entra CVE com **exploração confirmada**.
- Tem força de regra: órgãos federais dos EUA têm **prazo obrigatório** para corrigir o que entra nele (diretiva BOD 22-01).
- **Dado real e vivo**: público, gratuito e atualizado toda semana. Cresceu de 1.713 para **1.734** em 18 dias.

Nossa pergunta: quais fabricantes concentram as vulnerabilidades exploradas nos últimos 12 meses — e quanto custa responder isso?

393.026

CVEs publicadas no mundo (NVD)

1.713 (0,4%)

com exploração confirmada (KEV)

299

entraram nos últimos 12 meses

Arquitetura: tudo provisionado por código

1

Coletar

Baixa o feed público da CISA.

ingest.sh

2

Guardar

> Cópia original, byte a byte:
a prova de origem.

S3 · camada raw

3

Organizar

> Limpa e padroniza: uma
linha por CVE.

S3 · trusted + Glue Catalog

4

Perguntar

> SQL com limite de gasto
por consulta.

Athena WorkGroup (100 MB)

Terraform empacotado como módulo · estado remoto em **S3 + DynamoDB** · workspace **av1** · schema declarado em código, **sem Glue Crawler**.

Dados confiáveis antes de qualquer análise

GRANULARIDADE

0

CVEs duplicadas: **1.713 linhas, 1.713 CVEs distintas**.
Uma linha por CVE, provada por consulta.

- Grão por produto descartado: **214** de 1.713 (12,5%) têm nome de produto ambíguo.

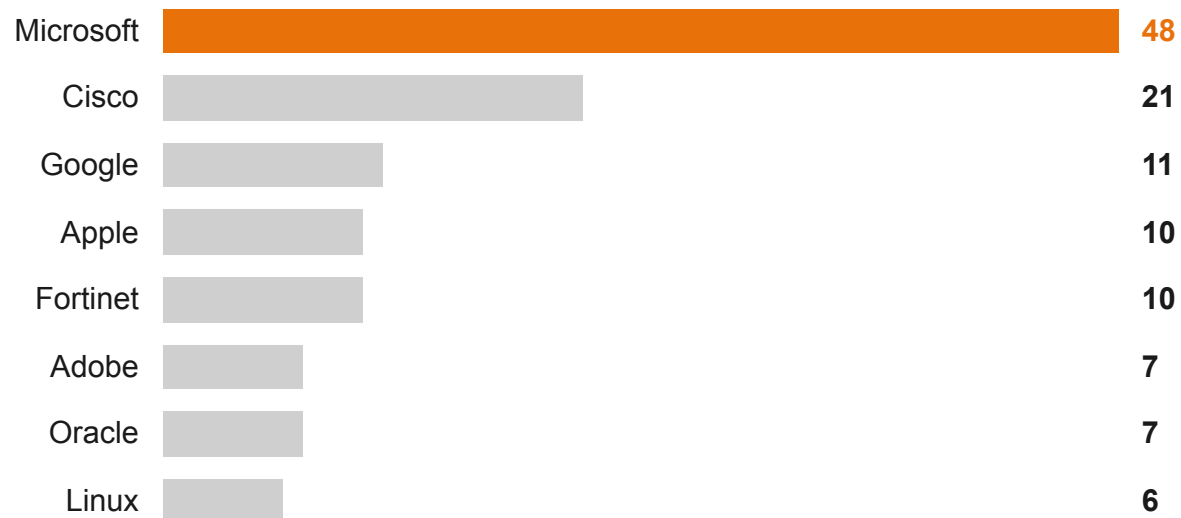
QUALIDADE RAW → TRUSTED

18 → 0

nomes com espaço sobrando. Sem a limpeza, o mesmo fabricante vira **dois grupos** no ranking.

- **5** barreiras de qualidade: se uma falha, nada é publicado.

A resposta: volume não é risco



CVEs exploradas adicionadas nos últimos 12 meses, por fabricante (299 no total). A Microsoft sozinha responde por 16%.

LIGADAS A RANSOMWARE

10% vs 43%

Microsoft (5 de 48) · Oracle (3 de 7)

A Oracle é só a 7ª em volume, mas quase metade das vulnerabilidades dela já foi usada em ransomware.

Quanto custa: medido, não estimado

US\$ 0,00004768

por consulta, lido da própria execução no Athena

≈ 21 mil

consultas com US\$ 1,00

- A consulta varre **3 MB**; o Athena cobra no mínimo **10 MB**. Já pagamos o piso.
- Parquet e particionamento economizariam **US\$ 0,00**. Ficam para a Parte 2, quando o volume passar do piso.
- Reexecutado do zero em 04/10, com 1.734 CVEs: **mesmo custo**.

Demonstração: do zero ao destroy

2 consulta no Athena com custo medido

```
Business question -- top vendors by KEV count, last 12 months

vendor_project      kev_count affected_products ransomware_linked pct_of_window most_recent_kev
Microsoft            49          15              5          15.96  2026-09-25
Cisco                19          13              2           6.19  2026-09-30
Apple               11           3              0           3.58  2026-09-29
Fortinet            11           6              0           3.58  2026-10-01
Google              10           5              0           3.26  2026-09-16
Linux                9           1              0           2.93  2026-09-18
Adobe               8           6              0           2.61  2026-09-24
Oracle              7           5              3           2.28  2026-08-24
Citrix              6           2              0           1.95  2026-10-04
Synacor             6           2              0           1.95  2026-08-21
Ivanti              5           3              0           1.63  2026-06-11
SonicWall           5           2              2           1.63  2026-09-02
Broadcom            4           4              1           1.3   2026-08-18
Check Point         4           3              1           1.3   2026-09-22
JFrog               4           1              0           1.3   2026-09-11

Measured cost
data scanned      : 3077872 bytes
billed            : 10485760 bytes (Athena 10 MB minimum applies)
engine runtime    : 807 ms (total 982 ms)
cost              : USD 0.00004768 at USD 5.00/TB
i.e.              : ~20973 runs of this query per USD 1.00
```

1 apply: recursos criados no workspace av1

```
OK Workspace      : av1
OK Raw bucket     : eda262-g07-lake-raw
OK Trusted bucket : eda262-g07-lake-trusted
OK Glue database  : eda262_g07_kev
OK Trusted table  : kev_vulnerabilities [grain: one row per cve_id]
OK Athena WorkGroup: eda262-g07-wg
```

3 verifica.sh: 25 PASSA / 0 FALHA

```
-----
PASSA Athena WorkGroup (eda262-g07-wg)
PASSA Dados carregados na camada trusted
PASSA Tags obrigatorias aplicadas nos recursos

-----
Resultado: 25 PASSA / 0 FALHA (total: 25 criterios)
Todos os criterios foram atendidos.
```

4 destroy: 27 recursos removidos, 0 órfãos

```
Destroy complete! Resources: 27 destroyed.
==> Verifying no resources were orphaned
OK No orphaned resources remain
```

Cada decisão, um número

DECISÃO	NÚMERO QUE A SUSTENTA
Uma linha por CVE	0 duplicadas
Limpeza raw → trusted	18 → 0 linhas sujas
Schema em código, sem Crawler	US\$ 0,073 evitados por execução
Sem Parquet na Parte 1	US\$ 0,00 de economia
Destroy verificado na AWS	0 recursos órfãos

DO PROJETO AO PRODUTO

A base de um serviço de **priorização de correção** por risco real, a **US\$ 0,00004768** por consulta.

PARTE 2

- **EPSS**: probabilidade de exploração de **373 mil** CVEs, todo dia.
- Particionamento medido: **12,2×** menos dados lidos.

Repositório: github.com/brunoribeiro/eda262-projeto-g07
Todas as decisões: DECISOES.md